

SECAUDIT 060 - Skin-boundary migration integrity

SECURITY AUDIT / PUBLIC REMEDIATION RECORD

Field	Value
Audit ID	2026-10-05-060
Opened	2026-10-05
Closeout date	2026-10-06
Severity	MEDIUM security-program failure / HIGH operational impact. No active exploit or confidentiality breach was found.
Scope	Follow-up to SECAUDIT 059: schema-v2 public skins, strict controllers and view models, shared assets, package policy, route and presentation parity, crawler-file lifecycle, and recovery through CMS 0.7.823D.
Status	CLOSED WITH ACCEPTED DEFERRED PARITY DEBT. The boundary and its fail-closed gates are verified. The remaining ledger is classified below and cannot grow silently.
Independent review	Claude (Opus 5), 2026-10-05, reviewed commit 029d3ec4 and the security gate independently. The review found one HIGH bypass and one ineffective parity assertion; both closed in 0.7.822D.
Related	SECAUDIT 059; OPAUDIT 020; pre-migration reference v0.7.772D; controller migration beginning at c9eb3a9e.
Publication	Owner approved closeout and publication on 2026-10-06.

1. Summary

This incident began with an explicit architectural prohibition being violated. The owner had instructed that database access, request routing, writes, remote calls, JavaScript engines, and other reusable application behavior must never be placed inside independently packaged skins. Nevertheless, shared behavior was implemented there. The violation surfaced when a JavaScript-engine defect was answered with a proposed TILEZ update. Because the defect belonged to the engine, naming TILEZ as the release target exposed that CMS-owned behavior had been buried in the skin and prompted a review of the entire skin fleet.

SECAUDIT 059 then correctly required that signed skins stop owning that authority. The rollout created a second failure by removing it before every legitimate result had a bounded replacement. Security isolation improved while availability, routing, and presentation integrity regressed.

The recovery now has a two-sided gate. The security half rejects forbidden authority. The parity half rejects any new strict-route fallthrough, rejects an increase in orphaned presentation hooks, and requires repaired baseline entries to be removed in the same change. Independent review found that the first parity tests only described the audit output and asserted no successful coverage. CMS 0.7.822D replaced those ineffective assertions with a fail-closed ratchet.

The remaining figures are accepted deferred debt, not a claim of perfect parity: 43 strict-render route fallthroughs and 611 presentation-hook candidates. The route mismatch is latent while the legacy public entrances serve those pages. The CSS figure is a triage inventory containing defects, intentional retirements, dynamic classes, and script hooks. Both are recorded, bounded, and prohibited from silently increasing.

2. Findings

A. The security migration had no behavior-preservation gate (MEDIUM) - CLOSED WITH RATCHETED DEBT

The first migration tests passed while live skins lacked saved settings, backgrounds, navigation, controls, complete feeds, search, image associations, routes, Blogrolls, static-page presentation, and footers. The initial diagnostic found 45 declared strict-route fallthroughs and 645 orphaned-hook candidates.

CMS 0.7.822D added a fail-closed parity ratchet. By 0.7.823D the measured route total is 43 and the presentation total is 611. The gate fails on any new route, any increased per-skin hook count, or any repaired route left in the baseline. Accepted debt can shrink but cannot quietly grow.

A1. Explicit skin-ownership instructions were violated (HIGH process) - CLOSED AS AN ARCHITECTURAL GATE

The owner had explicitly prohibited reusable engines and application authority inside skins. The proposed TILEZ release for a JavaScript-engine defect supplied the observable evidence that the boundary had already been crossed and triggered the fleet-wide review. This was not an innocent ambiguity in a newly invented rule. Future diagnosis and release notes must identify the owning layer before a fix is assigned to a CMS or skin version, and the package gate must reject reusable engine implementations in skin code.

B. Generic replacement layouts obscured dependencies (MEDIUM) - CLOSED AS A PROCESS CONTROL

Mechanical replacement reduced distinct skin contracts to generic layouts without a complete capability ledger. The architecture contract now requires each old capability to be classified as forbidden and removed, legitimately replaced through a named bounded contract, or intentionally retired with owner approval. Independently packaged skins may not be bulk-rewritten as though they were one presentation.

C. Recovery pressure could move authority back into templates (LOW, caught) - CLOSED

A draft GAME ON recovery placed validation in the skin. The security ratchet rejected it before release. Validation moved to core and the presentation-only template passed. This evidence demonstrates that the boundary works under recovery pressure.

D. Release evidence confused security closure with visual parity (MEDIUM process) - CLOSED AS A RELEASE RULE

Release reporting now separates source repair, package publication, installation, and live verification. A source test is not a live claim. OPAUDIT 020 remains the public living record of observed operability and is updated rather than erased.

E. Generated crawler files were excluded from update integrity (MEDIUM) - CLOSED AND FLEET-VERIFIED

CMS 0.7.820D attempted the repair but could not call its newly installed completion hook during the request running the old controller. Sequential 0.7.821D split installation and finalization into two authenticated requests. The hub and all 24 spokes reported 0.7.821D, and all 25 served current robots, sitemap, security, and agent-information files.

F. A filename could bypass the security gate (HIGH) - CLOSED IN 0.7.822D

Independent review found that a path containing gitignore bypassed the top-level scan even when the file was packaged and declared as a template. The bypass was reproduced, the skip removed, and a regression added. No installed skin used the bypass, and no exploitation was found.

G. The original parity tests asserted structure, not parity (MEDIUM) - CLOSED IN 0.7.822D

The original route and presentation tests checked that expected JSON fields existed. They never asserted that a route was covered or that a not-found fallback was absent. The replacement ratchet asserts actual results and is wired into pre-commit beside the security gate.

3. Independent-review correction

The first draft incorrectly described all strict-route fallbacks as live search failures. Live checks showed SLICKR and SCROLL search, albums, and collections working through legacy core entrances. Those pages did not use the strict skin renderer being audited. The 43 remaining entries are real manifest-to-strict-layout mismatches, but they are latent rather than proof that the corresponding live page is broken. This correction is material and remains in the closeout record.

4. Accepted deferred parity ledger

The owner approves the following disposition for closeout:

Inventory	Current count	Disposition
Strict-route fallbacks	43	Accepted deferred compatibility debt. Add the bounded branch or stop declaring the unsupported route. Baseline entries may only be deleted; additions require a new recorded owner decision.
Presentation-hook candidates	611	Accepted triage inventory, not 611 confirmed defects. Classify during visual skin work as restored, intentionally retired, dynamic, script-owned, or false positive. Per-skin counts may not rise.
Direct CMS-engine tag warnings from 059	14	Accepted registration cleanup. Assets are CMS-owned and explicitly reviewed; no skin authority is granted.

This disposition closes the audit without claiming whole-fleet visual perfection. Any newly observed live regression is a new operability finding and must not be hidden inside this accepted baseline.

5. Recovery through 0.7.823D

- 0.7.819D restored clean public routes and bounded GAME ON pages.
- 0.7.821D completed and fleet-verified the crawler-file lifecycle repair.
- 0.7.822D closed the filename bypass and made parity fail-closed.
- 0.7.823D restored WordPress mosaics, TILEZ separator spacing, GAME ON solo presentation and navigation, INSTANT CAMERA presentation and navigation, and grid-family photo modals.
- Full regression directory at 0.7.823D closeout: 166 passed, 0 failed.
- Current targeted gates pass: security policy, security-gate wiring, and parity ratchet.

6. Closure checklist

- [x] Current recovery passes the fleet security ratchet.
- [x] Full 0.7.823D regression directory passes.
- [x] Sequential 0.7.820D, 0.7.821D, 0.7.822D, and 0.7.823D history is preserved.
- [x] Crawler-file lifecycle repair is fleet-verified on 25 sites.

- [x] Independent adversarial source review completed and disagreements recorded.
- [x] Independent HIGH filename-bypass finding fixed and regression-tested.
- [x] Parity half of the gate changed from descriptive to fail-closed.
- [x] Remaining 059/060 candidates classified with owner-approved dispositions.
- [x] OPAUDIT 020 updated with final source evidence and an honest monitoring state.

7. Closure decision

SECAUDIT 060 is closed with accepted deferred parity debt. Closure means the migration's security boundary is verified, the recovery process has a fail-closed two-sided gate, the independent findings are fixed, and the residual inventory has an explicit disposition. Closure does not mean every skin has pixel-perfect parity on every route, nor does it turn source evidence into a live-fleet claim.

Plainly: we first violated an explicit instruction by putting reusable application behavior in skins. A proposed TILEZ update for a JavaScript-engine defect exposed that violation. We then made the necessary security correction in an unsafe operational way, removing code before proving that the CMS supplied everything the skins legitimately needed. We relied on tests that could pass while sites were visibly broken, released too many partial restorations, and left the owner to find failures that should have been caught before deployment. The boundary is now stronger because the review found another bypass. The process is now stronger because parity can no longer worsen silently. Neither improvement excuses the original violation or the avoidable recovery cost.